

密码学导论大作业作品设计报告

PB24151756 郑怡诺

作品题目：基于击键行为特征的本地行为口令身份鉴别系统

2026 年 5 月 25 日

基本信息表

作品题目：基于击键行为特征的本地行为口令身份鉴别系统

作品类别：☒ 软件设计 ☐ 硬件制作 ☐ 工程实践 ☐ 密码技术应用 ☐ 其它

作品内容摘要：

本项目实现了一个基于击键行为特征的本地行为口令身份鉴别系统。系统在校验字符口令（采用 PBKDF2-SHA256 哈希加盐存储）的基础上，额外采集用户的按键时长、间隔、纠错比例等行为特征，利用多样本建模和自适应阈值进行双重认证。整个系统使用 Python 和 Tkinter 编写，支持本地离线运行，适合作为终端设备的轻量级增强认证方案。

关键词（五个）：

行为口令，击键动态，身份鉴别，特征提取，本地认证

1. 作品功能与性能说明

本系统旨在演示“传统密码+行为特征”的双重认证逻辑，先校验口令，再比对行为特征。若口令正确但行为特征偏差过大，系统仍判定验证失败。系统的主要功能包括：

- 模板录入：采集用户 5 次相同口令的输入，提取行为统计指标生成本地模板。
- 身份验证：先进行字符口令哈希校验，校验失败时直接拒绝；校验通过后再进入行为特征比对。
- 结果解释：验证结果中不仅显示通过或拒绝，还会给出综合偏差值、阈值和偏差最大的几个特征，便于分析原因。
- 模板管理：支持查看本地已保存用户模板、刷新列表和删除模板，模板数据统一保存在 data/profiles.json。其中字符口令不以明文形式保存，而是保存随机盐值、口令哈希、哈希算法、迭代次数和口令长度等必要字段。
- 离线运行：界面、建模、验证和数据存储都在本机完成，不需要服务器或联网环境。

从性能上看，系统采用的是统计特征和加权距离计算，没有使用训练成本较高的模型。一次验证主要包括字符口令哈希校验和 9 维行为特征的加权偏差计算，整体计算量较小，能够满足本地实时验证需求。

2. 设计与实现方案

系统整体分为交互界面、击键事件采集、特征处理与模板建模、口令哈希校验、验证决策和本地存储六个部分。界面层负责录入和验证操作，采集层记录按键事件，特征处理层提取行为统计量，验证决策层完成口令校验和行为距离判断，本地存储层负责模板保存与读取。

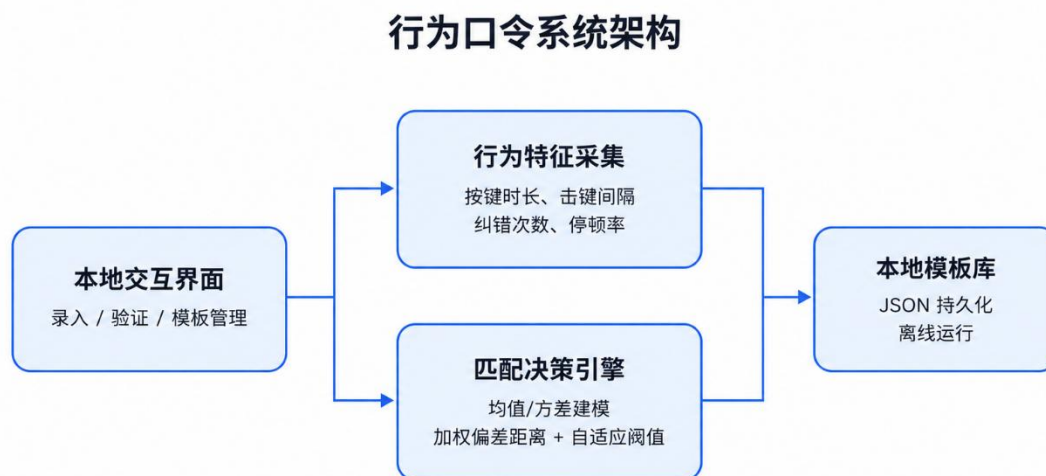


图 1：行为口令系统结构

2.1 实现原理

行为口令的基本假设是：同一用户的击键节奏（如按键长短、停顿习惯、纠错频率）具有相对稳定性，攻击者难以完美复现。因此，本作品在传统口令认证的基础上，进一步记录输入过程中的时间特征，并将这些特征整理成用户行为模板，用于后续身份鉴别。

在代码实现上，系统通过 `TypingCapture` 类监听键盘事件，计算按键时长和相邻按键间隔，提取出 9 个维度的核心特征：总输入时长、平均按键按下时长、按键时长波动、平均相邻击键间隔、击键间隔波动、最长停顿间隔、击键速度、纠错比例和停顿比例。

特征名称	含义	在验证中的作用
总输入时长	完成整串口令输入所用时间	反映整体输入速度，过快或过慢都会拉大偏差
平均按键按下时长	每个键从按下到抬起的平均时间	反映用户按键习惯，常用于区分轻敲和长按
击键间隔	相邻可打印字符按下时间差	反映输入节奏，是行为口令中比较关键的指标
最长停顿间隔	一次输入过程中最大的间隔	用于捕捉犹豫、查找符号或临时停顿
纠错比例	Backspace/Delete 在总按键中的占比	反映输入熟悉程度和出错习惯
停顿比例	超过设定间隔的停顿数量占比	用于补充说明输入过程中是否存在异常停顿

模板建立时，默认采集 5 组注册样本，最低支持 3 组有效样本生成用户模板。对每个特征分别计算均值和标准差。由于样本数较少时标准差可能过小，代码中为每个特征设置了下限 `FEATURE_FLOORS`，避免某个指标因为标准差接近 0 而导致偏差被无限放大。

验证时，系统先进行字符口令哈希校验。校验不通过时直接拒绝，这一步保留了传统口令认证的基本安全性；校验通过后，再计算当前样本在各行为特征上的归一化偏差：

$$z = |x - \mu| / \max(\sigma, \text{floor})$$

其中 x 是当前输入的特征值， μ 是模板均值， σ 是模板标准差，`floor` 是该特征的标准差下限。随后系统按 `FEATURE_WEIGHTS` 中的权重加权平均得到综合偏差 D 。

代码会先用录入样本计算模板，再把这些录入样本反过来与模板比较，得到录入阶段的平均距离和最大距离。最终阈值取 1.55、平均距离加 3 倍标准差、最大距离加 0.12 三者中的较大值，同时不超过 2.60。这样做既给真实用户保留一定自然波动空间，又避免阈值过宽导致仿冒输入容易通过。

录入与验证流程

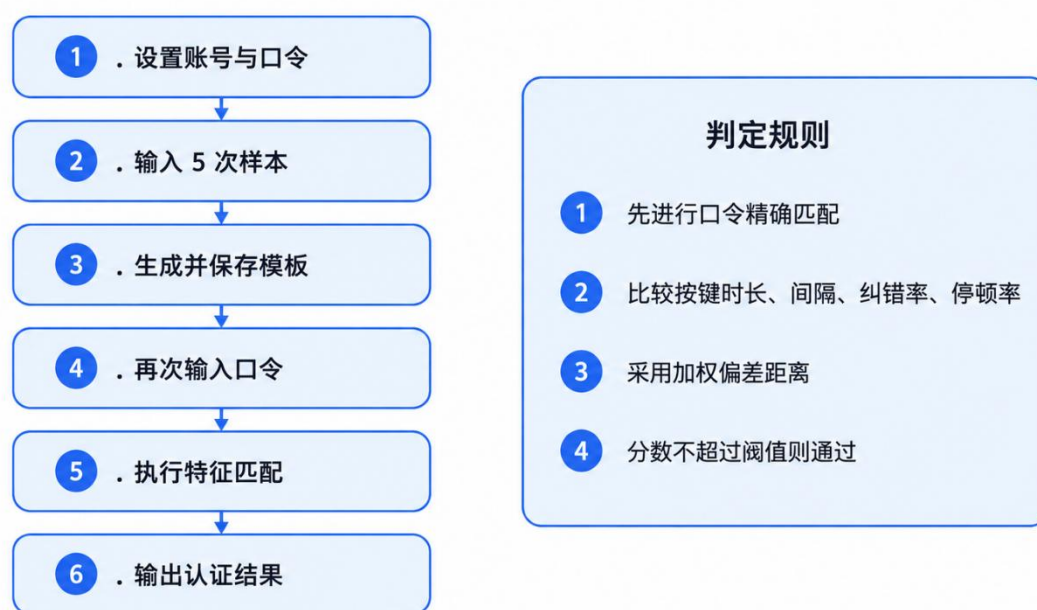


图 2：录入与验证流程

2.2 运行结果

程序入口为 `app.py`。界面分为“录入建模”“身份验证”“模板管理”三个页签，分别完成样本采集、验证判定和模板维护。录入完成后，系统将行为样本、特征统计量、阈值及口令哈希字段写入本地 JSON 文件。

验证页先从本地模板列表中选择用户，再输入同一字符口令并点击执行验证。如果哈希校验失败，界面会提示“字符口令不匹配”，并且不会进入行为特征比对；如果字符口令正确，程序会调用 `evaluate_sample` 计算综合偏差值并给出判定结果。模板管理页用于查看已经保存的用户模板，显示保存时间、阈值和部分样本信息，也可以删除不需要的模板。

验证通过：



图 3：验证通过界面

口令不匹配：

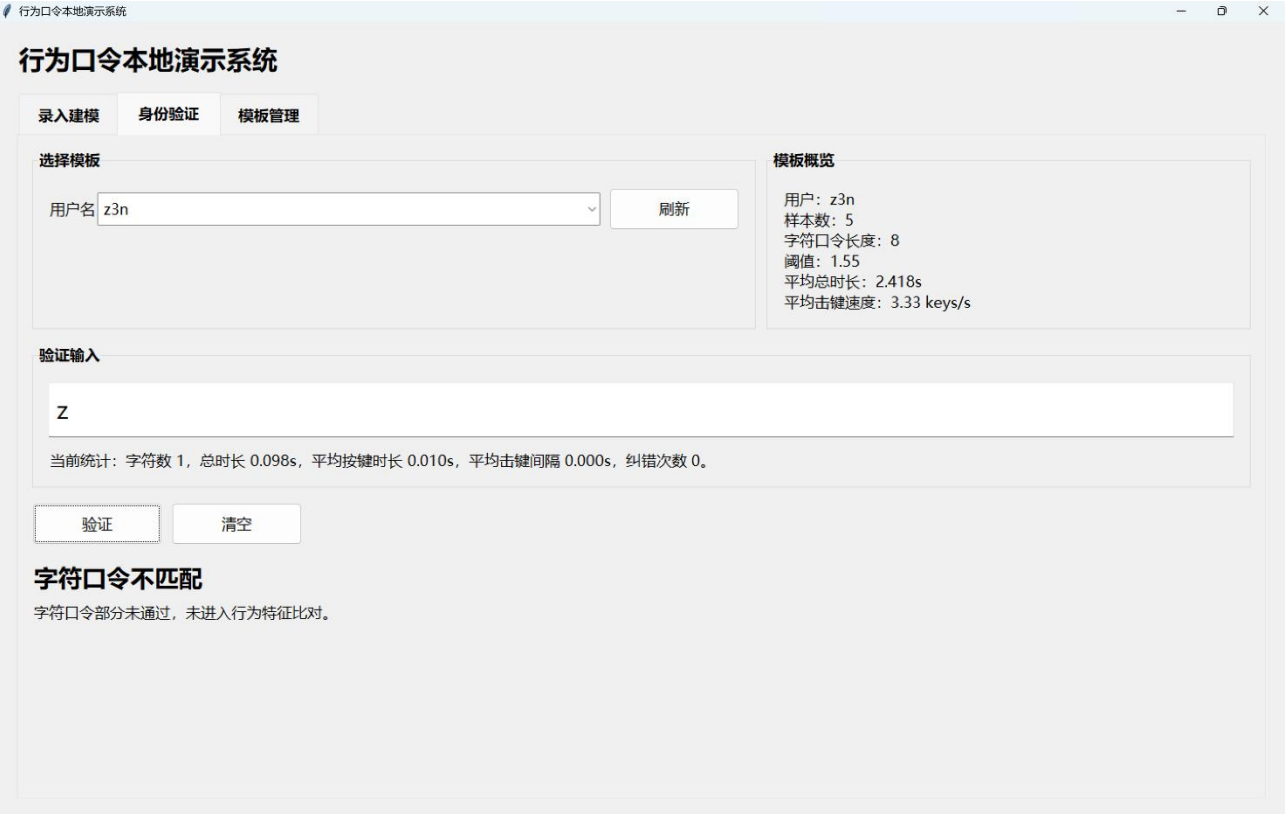


图 4：口令不匹配界面

字符口令匹配但行为口令不匹配：



图 5：字符口令匹配但行为口令不匹配界面

2.3 技术指标

系统主要技术指标如下：

指标项	当前实现
字符口令要求	8-20 位 ASCII 字符，避免输入法影响击键事件采集
口令存储方式	采用 PBKDF2-SHA256 结合随机 salt 进行哈希存储，不保存明文口令。
默认模板样本数	默认采集 5 组注册样本，最低支持 3 组有效样本生成用户模板
行为特征维度	9 个统计特征，包括总时长、按键时长、击键间隔、纠错比例等
示例模板阈值	基于注册样本内部距离动态校准，默认阈值下限为 1.55
示例数据表现	40 组模拟真实样本通过率 100.0%，40 组仿冒样本误接受率 0.0%

3. 系统测试与结果

3.1 测试方案

测试使用固定口令 Alpha9!Key。本实验基于注册模板构造 40 组模拟真实用户样本和 40 组模拟仿冒样本进行验证。模拟真实用户样本围绕模板均值做小幅波动，仿冒样本在输入总时长、击键间隔、停顿比例和纠错比例上加入更明显差异。每个样本都经过同一套 evaluate_sample 逻辑计算偏差值、阈值和匹配分数。

功能测试主要分为五个流程：新建模板、字符口令比对、行为特征比对、模板删除和结果解释。性能统计主要记录真实用户通过率、误拒绝率、仿冒样本误接受率等。

3.2 功能测试

测试项	测试内容	结果
新建模板	连续保存 5 次样本后生成模板并落盘	通过
字符口令比对	字符口令错误时直接拒绝，不进入行为判断	通过
行为特征比对	字符正确时计算综合偏差并与阈值比较	通过
模板删除	删除本地模板后刷新列表	通过
结果解释	显示偏差值、阈值、匹配分数和主要差异项	通过

3.3 性能测试

40 组模拟真实用户样本全部通过，通过率 100.0%，误拒绝率 0.0%；40 组仿冒样本全部被拒绝，误接受率 0.0%。在当前示例数据中，真实样本偏差值多在 0.3~0.9，仿冒样本多高于 1.8，说明行为特征具有一定区分作用。

样本类别	编号	偏差值	阈值	判定
模拟真实用户	1	0.890	1.550	通过
模拟真实用户	2	0.735	1.550	通过
模拟真实用户	3	0.600	1.550	通过
仿冒样本	1	2.231	1.550	拒绝
仿冒样本	2	2.189	1.550	拒绝
仿冒样本	3	1.904	1.550	拒绝

从结果解释看，模拟真实用户样本即使在某一两个指标上有偏差，综合距离通常仍处于可接受范围；仿冒样本则经常同时在总输入时长、平均击键间隔、停顿比例或纠错比例上偏离模板，因此综合偏差更高。这个现象也符合直觉：攻击者只知道口令内容时，可以复制字符序列，但不容易复制输入节奏。

3.4 测试数据与结果

本实验的结果有两个比较明显的特点。第一，模拟真实样本的偏差值与仿冒样本之间有较清楚的间隔，说明简单统计特征在演示场景下已经能体现行为差异。第二，阈值 1.55 对当前数据比较保守，既能覆盖录入样本自身波动，又能把仿冒样本排除在外。

4.应用前景

行为口令适合作为传统口令的增强层。对于本地终端登录、实验室设备控制、离线业务系统二次确认等场景，它能在不明显增加操作负担的情况下提高口令泄露后的防护能力。

但当前系统仍有局限：一是测试样本较理想化，100% 拦截率只能说明当前算法逻辑有效，不能代表真实攻击者的模仿能力；二是行为模板仍以本地 JSON 明文保存，若攻击者获得本地权限，可能读取或篡改阈值，后续需加入文件加密、访问控制和 HMAC 完整性校验。

后续可增加按键重叠、特定位置停顿等特征，引入模板自适应更新，扩大真实用户样本，并结合设备指纹、鼠标行为或一次性验证码形成更完整的多因素认证方案。

5. 结论

本作品实现了基于击键行为特征的本地行为口令身份鉴别系统，完成模板录入、口令哈希校验、行为特征提取、加权偏差判定和结果解释等功能。示例数据表明，该方法在当前实验条件下具有一定区分效果。

总体来看，系统体现了“口令秘密 + 个体习惯”的增强认证思路。但其仍属于轻量级本地认证原型，在模板保护、真实用户样本规模、长期稳定性和异常登录处理方面仍需完善，暂不适合直接用于高安全等级认证场景。

附 github 仓库地址：

[zyn325604/Behavioral-Password](https://github.com/zyn325604/Behavioral-Password): 密码学导论大作业：行为口令认证系统